

Data Privacy & Protection Policy

Policy No: POL-IT-003 | Version: v2.0 | Department: Legal & Compliance / IT | Effective: March 17, 2026

1. PURPOSE

This policy establishes guidelines for the collection, storage, processing, and disposal of personal and sensitive data. It ensures compliance with applicable data protection laws including GDPR, IT Act 2000 (India), and other regional regulations.

2. SCOPE

This policy applies to all employees who access, process, or handle personal data of customers, employees, or any other individuals on behalf of the organization.

3. TABLE OF CONTENTS

Section	Title
4	Data Protection Principles
5	Personal Data Handling
6	Data Storage & Retention
7	Data Transfer
8	Employee Rights & Obligations
9	Breach Response

4. DATA PROTECTION PRINCIPLES

All processing of personal data must adhere to the following core principles:

- **Lawfulness, Fairness & Transparency:** Data is processed lawfully with a valid legal basis and individuals are informed of how their data is used.
- **Purpose Limitation:** Data collected for a specific purpose is not used for other unrelated purposes.
- **Data Minimisation:** Only the minimum amount of data necessary is collected and processed.
- **Accuracy:** Personal data must be kept accurate and up to date.
- **Storage Limitation:** Data is retained only as long as necessary for its stated purpose.
- **Integrity & Confidentiality:** Data is protected against unauthorized access, loss, or destruction.

5. PERSONAL DATA HANDLING

5.1 Collection

Personal data must only be collected with explicit consent or other lawful basis. Employees must inform individuals about what data is collected, why it is collected, and how it will be used.

5.2 Processing

- Access personal data only when required for your job role.
- Do not process personal data for personal reasons or unauthorized purposes.
- Obtain manager approval before sharing personal data with third parties.

5.3 Special Category Data

Health, biometric, financial, religious, and political data are classified as Special Category Data and require explicit consent and enhanced security measures. Contact the Data Protection Officer (DPO) before processing such data.

6. DATA STORAGE & RETENTION

6.1 Storage Requirements

- Personal data must be stored only in company-approved systems and locations.
- Storing personal data on personal devices, USB drives, or unauthorized cloud storage is prohibited.
- All stored personal data must be encrypted using AES-256 or equivalent.

6.2 Retention Periods

- Employee records: 7 years after termination.
- Customer data: As defined in contract, typically 5 years post-relationship.
- Recruitment data (unsuccessful candidates): 6 months.
- Financial records: Minimum 8 years per regulatory requirements.

6.3 Secure Disposal

Data must be disposed of securely using approved methods: digital data via certified wiping software; physical documents via cross-cut shredding.

7. DATA TRANSFER

- Personal data must not be transferred outside the organization without proper authorization.
- Transfers to third-party vendors require a Data Processing Agreement (DPA).
- International transfers require compliance with applicable cross-border data transfer regulations.
- Email transfers of personal data must use encrypted email or secure file transfer.
- Never send personal data via unencrypted messaging apps or personal email accounts.

8. EMPLOYEE RIGHTS & OBLIGATIONS

8.1 Employee Obligations

- Complete mandatory data privacy training within 30 days of joining.
- Report any suspected data misuse or breach immediately.
- Do not access personal data beyond your authorized scope.

8.2 Individual Data Rights

Employees and customers have rights under applicable law including: Right to Access, Right to Rectification, Right to Erasure, Right to Portability, and Right to Object. All such requests must be forwarded to the DPO within 24 hours.

9. BREACH RESPONSE

A data breach is any unauthorized access, disclosure, alteration, or destruction of personal data.

9.1 Reporting

Employees must report suspected breaches to it-security@company.com and the DPO within 1 hour of discovery. Do not attempt to investigate independently.

9.2 Response Timeline

- 0-1 hour: Internal notification to IT Security and DPO.
- Within 24 hours: Internal assessment and containment.
- Within 72 hours: Regulatory notification if required by law.
- Within 7 days: Full incident report and remediation plan.

ACKNOWLEDGEMENT

EMPLOYEE ACKNOWLEDGEMENT

I, the undersigned, confirm that I have read, understood, and agree to comply with this policy. I understand that violation of this policy may result in disciplinary action.

Employee Name:	_____	Date:	_____
Employee ID:	_____	Signature:	_____
Department :	_____	Manager:	_____

For questions regarding this policy, contact the IT Department at it-policy@company.com